DE DANSKE CYBERMESTERSKABER

Pentesting

An Introduction

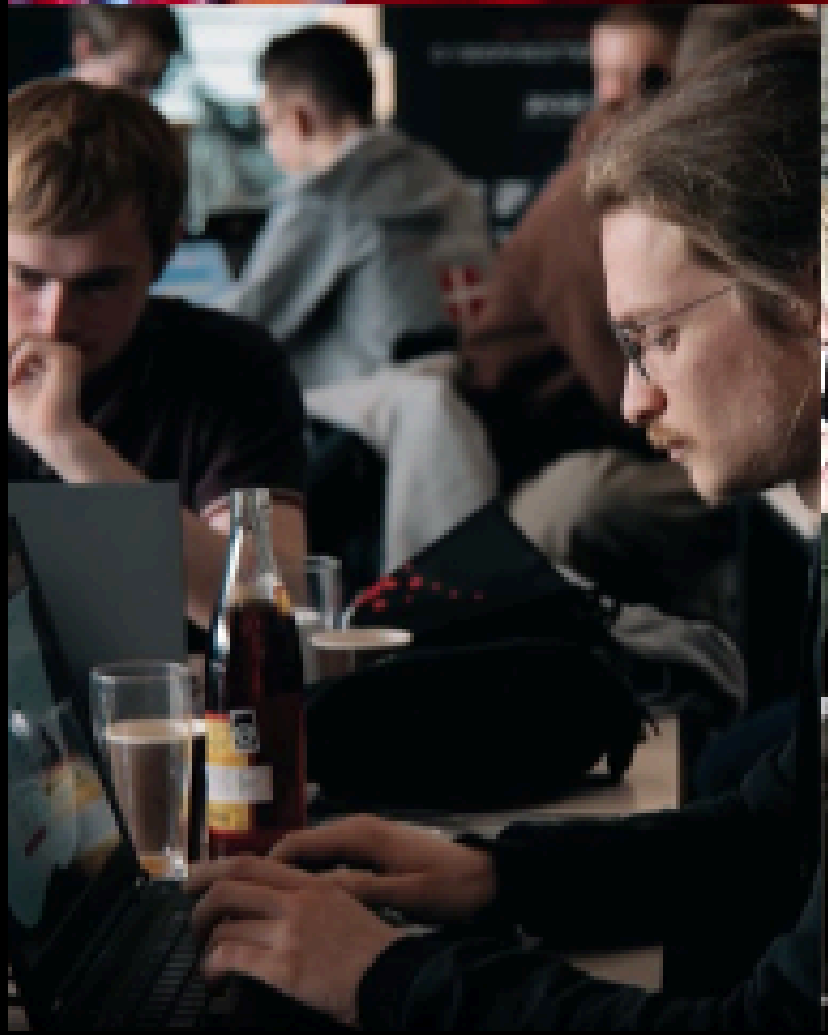
Shreyas Srinivasa, Ph.D.
Cybersecurity Specialist, TERMA A/S

March 01.25

DE DANSKE
CYBERMESTERSKABER


DENMARK
INDUSTRIENS FOND
Cyberlandsholdet

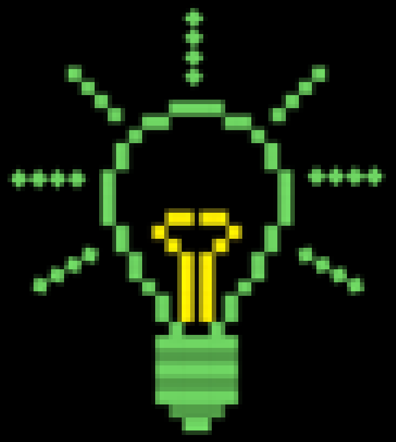

INDUSTRIENS FOND




DE DANSKE
NATIONALS 2024

DDC 2025

ONLINE
TRÆNINGSDAGE



FEBRUAR-MARTS

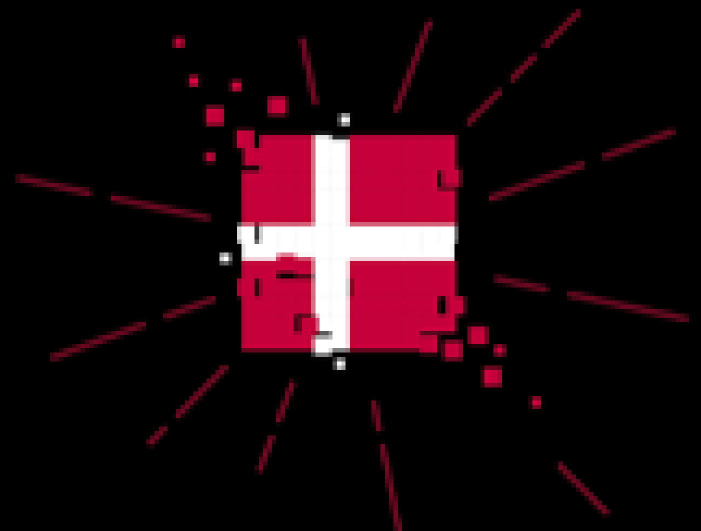
ONLINE
KVALIFIKATION

22.FEB-16.MARTS

REGIONALE
MESTERSKABER

5.APRIL

DE DANSKE
CYBERMESTERSKABER



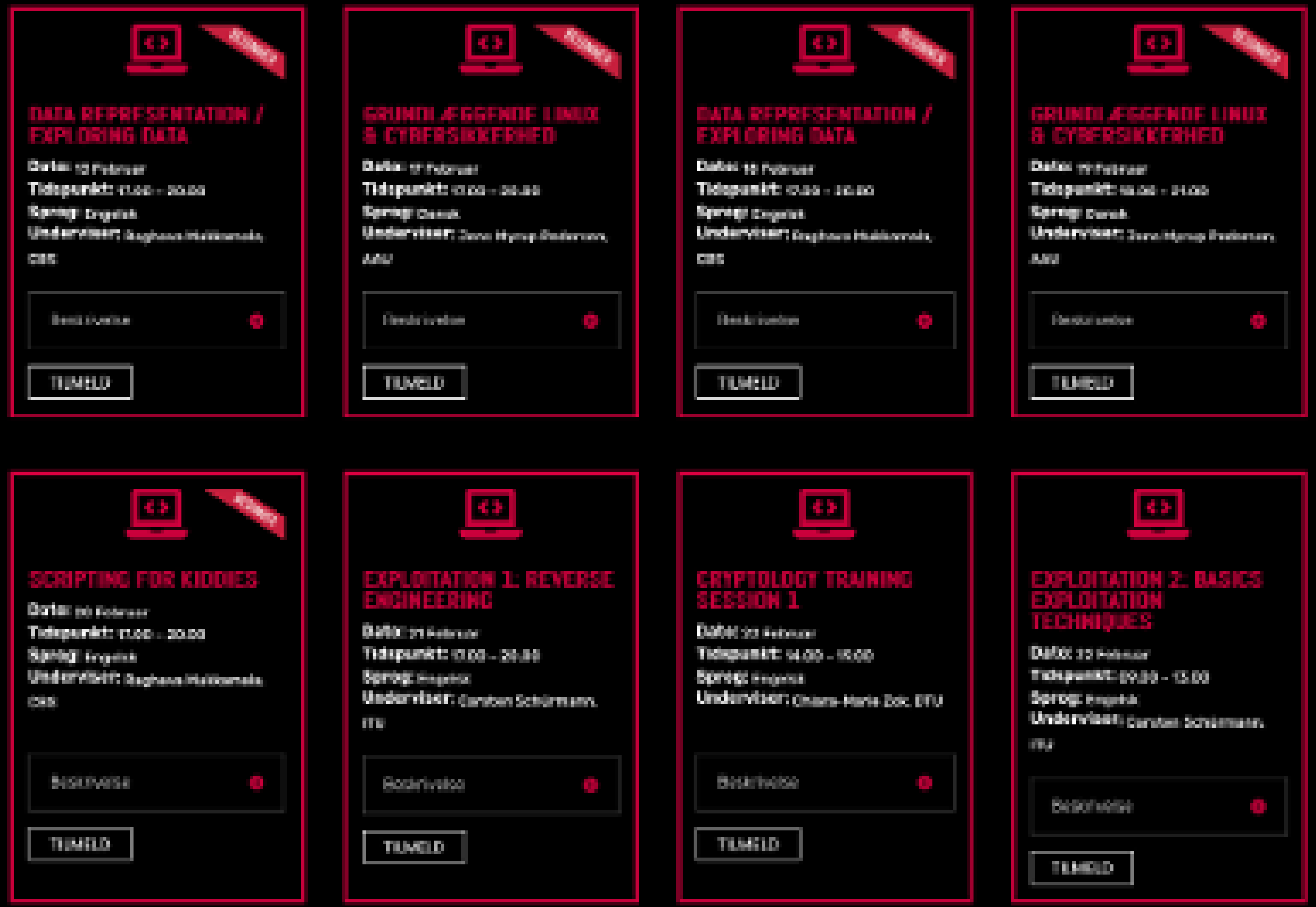
3.MAJ

Online træninger (februar-marts)

online træninger er for ALLE

Du finder træninger indenfor temaerne:

- Grundlæggende Linux og Cybersikkerhed
- Data Representation / Data Exploring
- Scripting for Kiddies
- Exploitation
- Cryptology
- Netværksscanning og Overvågning
- Forensics
- Penetration Testing
- Grundlæggende Web-sikkerhed
- Software Verification
- DDOS



Online kvalifikation (22. feb. - 16. marts)

Alle kan være med til online kvalifikation, men kun 15-25 årige kan gå videre efterfølgende. - I vil kunne se disse bokse fra d. 22. februar på websitet.

*Det er din alder per 31.12.2025 som er gældende

JUNIOR (15-20 ÅR)

ONLINE KVALIFIKATION
22. FEBRUAR - 16. MARTS

TILMELDING ÅBNER D. 22. FEB.

SENIOR (21-25 ÅR)

ONLINE KVALIFIKATION
22. FEBRUAR - 16. MARTS

TILMELDING ÅBNER D. 22. FEB.

OPEN

Åben for alle, der ikke hører til aldersgruppen 15-25 - Du deltager IKKE i konkurrencen i denne kategori
22. FEBRUAR - 16. MARTS

TILMELDING ÅBNER D. 22. FEB.

Regionals (5. april)

Afholdes i de 5 regioner: Hovedstaden, Midtjylland, Nordjylland, Sjælland og Syddanmark.
Afholdes virtuelt, men der er mulighed for fysisk fremmøde!

Hvem går videre til Nationals?

- De regionale vindere
- De 4 runner ups i hver aldersgruppe fra hver region
- Top 25 i hver aldersgruppe på landsplan

Nationals (3. maj)

Nationals afholdes fysisk på Aalborg Universitet i København.
10 timers intens konkurrence (kl. 10-20) herefter pointtælling og annoncering af vindere.
Alle deltagere får transportrefusion, mad og drikke.


DENMARK
INDUSTRIENS FOND
Cyberlandsholdet
INDUSTRIENS FOND
DE DANSKE
NATIONALS 2024

DE DANSKE
CYBERMESTERSKABER

Pentesting

An Introduction

Shreyas Srinivasa, Ph.D.
Cybersecurity Specialist, TERMA A/S

March 01.25

Agenda

this evening ...

01 Introduction

- Pentesting, vs. Hacking, vs. Red Teaming
- Types
- Workflow

02 Tools & Techniques

- Recon & Enumeration (with NMap, Wappalyzer, Nikto)
- Exploitation (ExploitDB, Metasploit, BurpSuite)
- Reporting

Shreyas Srinivasa, Ph.D.

- 34 yrs, from **Bengaluru, India**
- **Ph.D.** from **Aalborg University**
- Bachelors @ **VTU, India** and Masters @ **TU Darmstadt, Germany**
- Work: 2 yrs in NOC, 6 yrs in SOC
- Research interests: Cyber Threat Intelligence, Cyber Deception, Cyber crime, Internet Security Measurements, OSINT (GOSI)
- Visiting scholar @ **University of Cambridge**, Cambridge Cybercrime Center
- Community service: community worker @**TraceLabs** (finding leads on missing children using OSINT), **Cyberpeace** Institute (NGO)
- Mentor @ **Google Summer of Code** from 2020
- A humble **coffee farmer**

Web: https://sastry17.github.io

Timeline

Introduction

Pentesting

Break - 20 minutes

Techniques and Tools + Activity

Overview of tools and techniques

Haaukins Challenges

Playground

Disclaimer

- This training is an introduction to pentesting and not redteaming
- The training is based on the principle of "Ethical Hacking"
- The aim is to understand preliminary concepts, techniques and tools
- **Please take consent before testing a real target (from the direct owner)**
- Have a legal binding before you perform PenTests
- **It is illegal to do Pentests without consent, and can be a punishable offense**

Material for today

https://github.com/sastry17/DDC-Pentest/blob/main/training.zip

PenTesting

Pentesting

What is it?

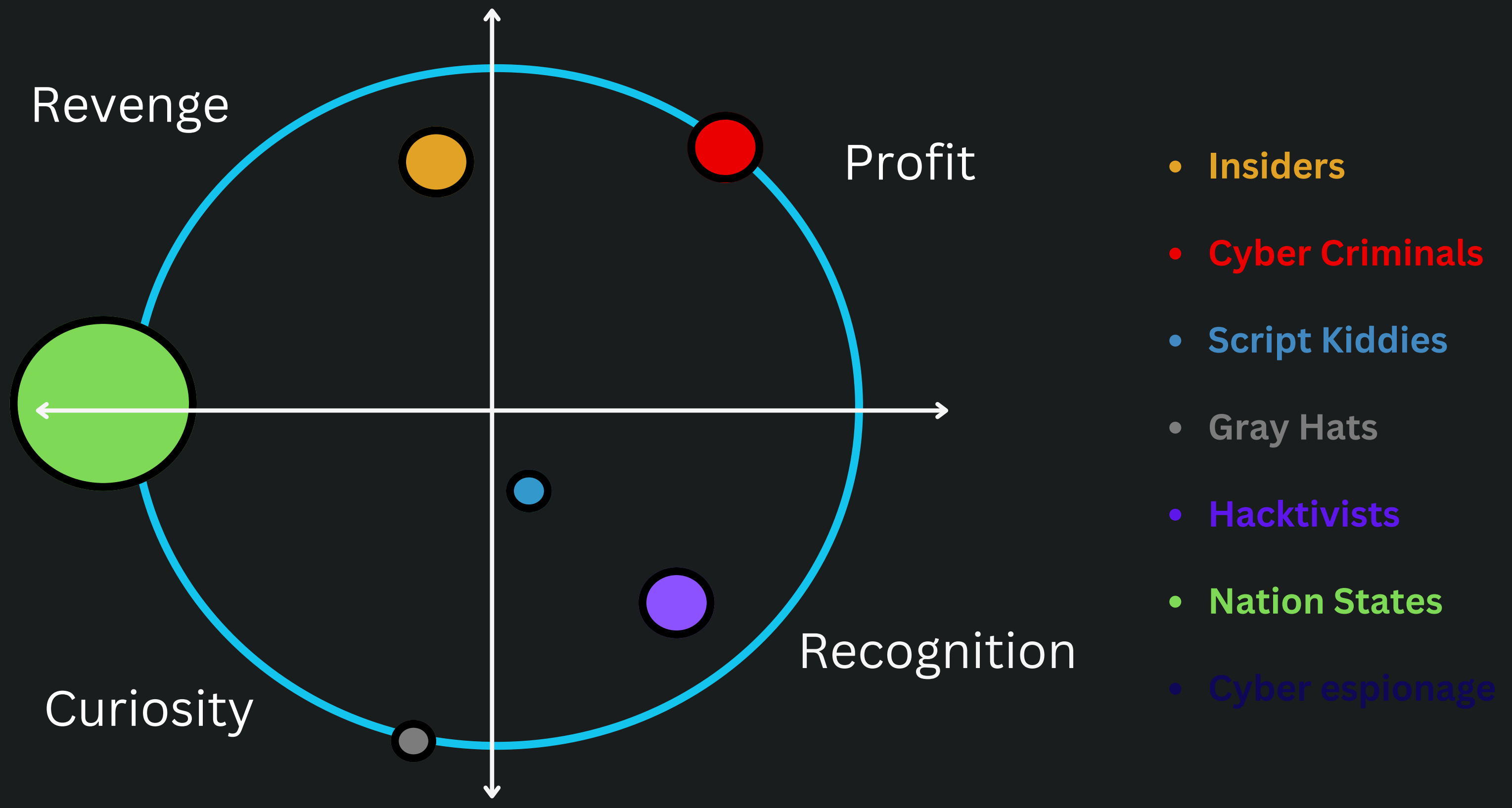
*"An **ethically agreed**, planned and **consented process**, to **test the security of a target system/service** from an **attacker perspective**"*

- Goals:
  - Identify the attack surface
  - Improve the security posture
  - Determine and reduce risk
  - Compliance

Pentesting vs Hacking

What it is not?

- Hacking in general perspective is an **“Unethical process”**
- Hacking does not take consent, and hence **there is always a “victim”**
- Hacking leads to **“Irresponsible Disclosure”**, **“Loss”** or **“Harm”**
- Hacking is motivated by **revenge**, **monetary profit**, **haktivism**



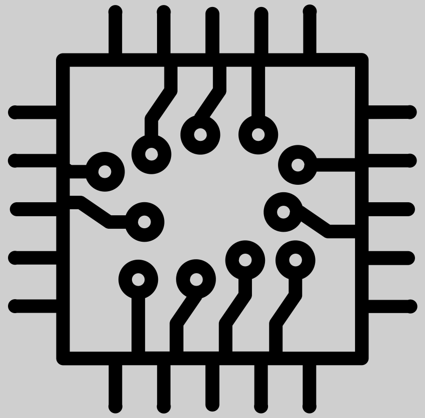
PenTesting vs Red-Teaming

A line of distinction

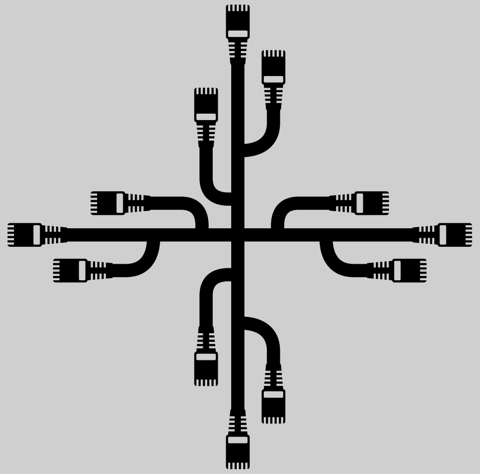
Aspect	PenTesting	Red-Teaming
Objective	Identify and exploit vulnerabilities with an agreed scope	Simulation of real-world attacks to test detection and response capabilities
Scope	Predefined targets and vulnerabilities within a limited timeframe.	Broader scope with multi-stage attacks and several attack vectors
Methodology	Systematic approach and structured process and techniques	Holistic approach that may involve technical attacks, social engineering and physical security assessments
Engagement	Conducted with consent with the target owner, organization/team is fully aware of system under test	Conducted as a secretive process, with the defensive team unaware of the process and timeline

PenTest-Types

Physical
access test



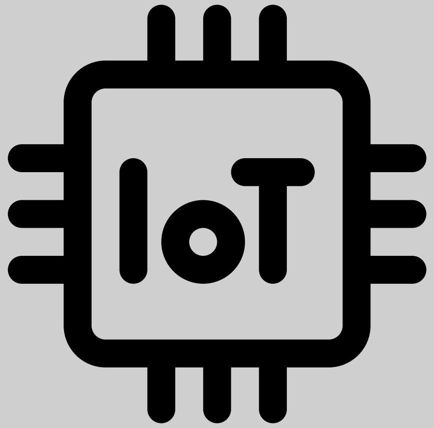
Hardware



Network

Web

App



IoT

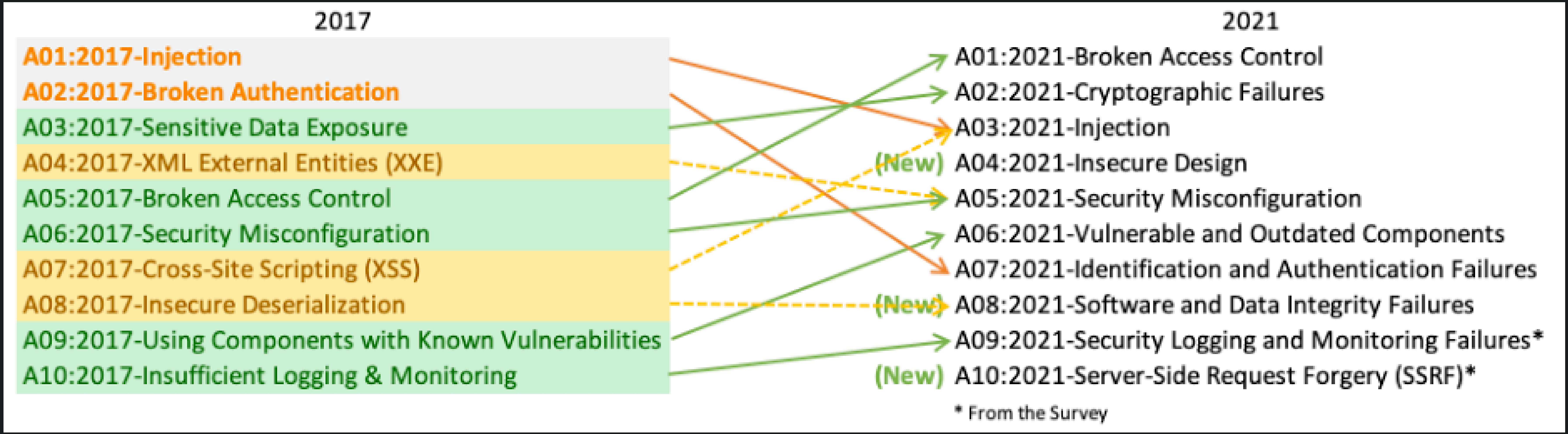
PenTesting Workflow

PenTesting Workflow

src: https://docs.rapid7.com/metasploit/

OWASP top 10 checks

- The OWASP Top 10 is a standard awareness document for developers and web application security.
- It represents a broad consensus about the most critical security risks to web applications



src: https://owasp.org/www-project-top-ten/

OWASP Resources for Web Testing

OWASP Web Penetration Testing Checklist (**19 Pages**)

https://owasp.org/www-project-web-security-testing-guide/assets/archive/OWASP_Web_Application_Penetration_Checklist_v1_1.pdf

OWASP Web Security Testing Guide (**465 Pages**)

https://github.com/OWASP/wstg/releases/download/v4.2/wstg-v4.2.pdf

Break? - (15min)

Tools & Techniques

Recon & Enumeration

- **Recon** - It is the “Information Gathering process”
  - Organizational Intelligence (OPSEC)
  - Metadata collection (DNS records, MX records, Social Engineering, Employee Listing, traceroutes, patents)
- **Enumeration** - Gather information about the target
  - network topology, service discovery, port-scanning
  - web-application enumeration - server software and versions, virtual hosts, folders and paths

Recon & Enumeration - Tools

- **Shodan and Censys** - OPSec and Information gathering - open ports, services, “history”
- **ExploitDB/searchsploit, NVD** - Database of reported vulnerabilities(NVD) and exploits(ExploitDB)
- **whois, RIPEdb, mxtools** - domain and IP information gathering
- **NMap** - IP Enumeration, Port-scanning, Service Discovery, OS Fingerprinting
- **Wappalyzer** - website technologies JS, CSS, HTML. Works as a browser extension
- **Wfuzz, Recon-ng** - DNS enumeration
- **wafw00f** - WAF detection
- **dirbuster** - web paths and directories

Hands On - Recon

1

- **Shodan & Censys**
  - Open web browser, Go to shodan.io
  - Search for “Telnet”
  - Open another tab on the browser
  - Go to https://search.censys.io
  - Search for “cybermesterskaberne.dk” :)

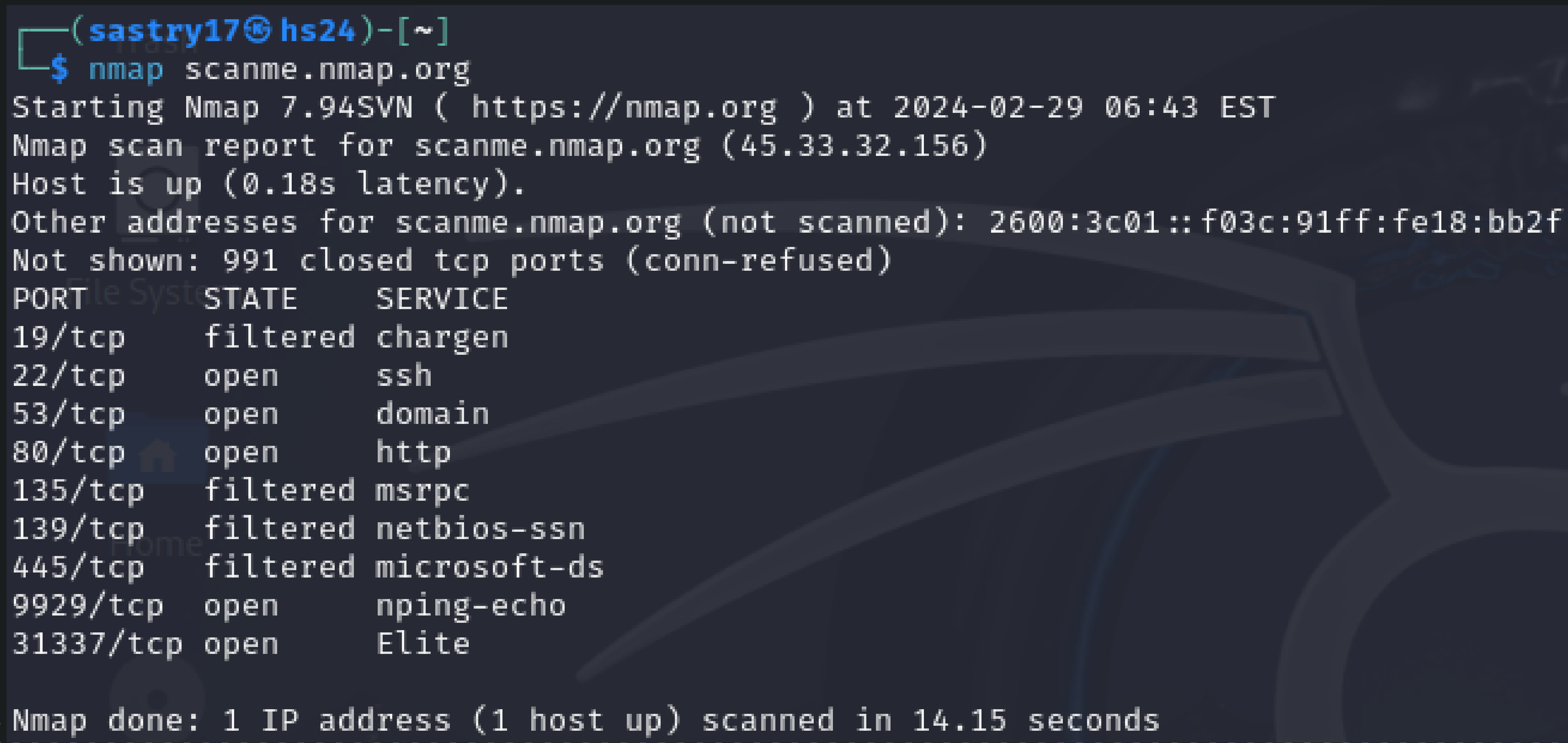
2

- **ExploitDB**
  - Open web browser, Go to exploit-db.com
  - Search for “samba 3.0.20” :)

HandsOn- NMap

NMap Activity:

- Launch NMap tool from your machines (Terminal -> nmap)
- type> **nmap scanme.nmap.org**
- Next, type> **nmap -sV scanme.nmap.org**
- Next, type> **nmap -v -O scanme.nmap.org**



Activity.1 - 20 mins

Open file “Activity1.pdf” from the zip file.

Activity1.1 - NMap

NMap Activity:

- Open URL> **https://ddcpentest.haaukins.com/** and **sign up!** ;)
- Start challenge > **“Network Scanning”** Click on Connect to open Kali instance
- Use nmap to scan for all available machines on the network!

Activity1.2 - Nikto

Nikto Activity :

- Open URL> **https://ddcpentest.haaukins.com/**
- Start challenge > "**Admin logon**" Click on Connect to open Kali instance
- Go to terminal and run> **nikto -h menne.com**

Activity1.3 - GrayhatWarfare(OPSec)

Activity:

- Go to> **https://buckets.grayhatwarfare.com/**
- Search> “abc corp“ ;)

GRAYHAT WARFARE
cause white is boring

Activity1.4 - ExploitDB

Activity:

- Go to> **https://www.exploit-db.com/**
- Search> **samba 3.0.20**

EXPLOIT DATABASE

Exploitation

Exploitation

- **Exploitation** - Using the knowledge of vulnerabilities and systems to exploit them for gaining access
- The exploit is determined based on the vulnerabilities identified in the information gathering phase
- However, the exploit needs to be developed or customized (if already developed) and tested
- After exploitation: Gaining control of the system, Privilege Escalation, Pivoting and Gathering evidence
- Techniques - reverse shells, injection attacks
- Tools - **Metasploit Framework(MSF)**, Burp Suite, Zed Application Proxy

Exploitation - Metasploit Framework

- MSF Framework : one of the most widely used tools for Pentesting
- Modules - Exploits, Payloads, Auxilliaries, Encoders
- Contains a collection of searchable exploits on diverse types of vulnerabilities
- Components - msfconsole, msfdb, msfvenom, meterpreter

Exploitation - Burp Suite

- comprehensive web application security testing tool that includes a range of features for vulnerability scanning, manual testing, and exploitation
- offers a built-in web proxy, scanner, intruder, repeater, sequencer
- widely used by security professionals and penetration testers for assessing the security posture of web applications.

Activity.2 - 30 mins

Open file “Activity2.pdf” from the zip file.

+ 15 mins break!

Activity2.1 - Metasploit

Metasploit Activity:

- Go to **https://ddcpentest.haaukins.com/**
- Start challenge **"Its Samba Time!"**
- Click on **Connect**, open Terminal
- scan the target system to find any open services and find vulnerabilities
  - **nmap -sV** ip
  - **search for vulnerabilities** for the discovered open services on exploitdb
- open **msfconsole**, search for related exploits
  - terminal> **msfconsole**
  - msf6> **search** xxxxx
  - **look for a matching exploit** and payload based on information from exploitdb
  - choose payload, set the target and **run the exploit**

Activity2.2 - BurpSuite

BurpSuite Activity:

- Go to **https://ddcpentest.haaukins.com/**
- Start challenge **“Admin-Logon”**
- Click on **Connect**, open Burpsuite from Kali Applications
- Try to intercept the traffic when you login to the webpage Menne
- Can you login as admin? It doesnt seem to check the password :/

Reporting

Reporting

- Generating a report on the findings of the pentest
- Intended for both Management and Technical teams. However, a brief “Management Summary” is included on the overall assessment
- The report includes - how the issue was found, how it was exploited and the remedies

Sample Reporting Structure

Based on: https://owasp.org/www-project-web-security-testing-guide/v42/5-Reporting/README

1. Introduction
    - 1.1 Version Control
    - 1.2 Contents
    - 1.3 The Team
    - 1.4 Scope
    - 1.5 Limitations
    - 1.6 Timeline
    - 1.7 Disclaimer

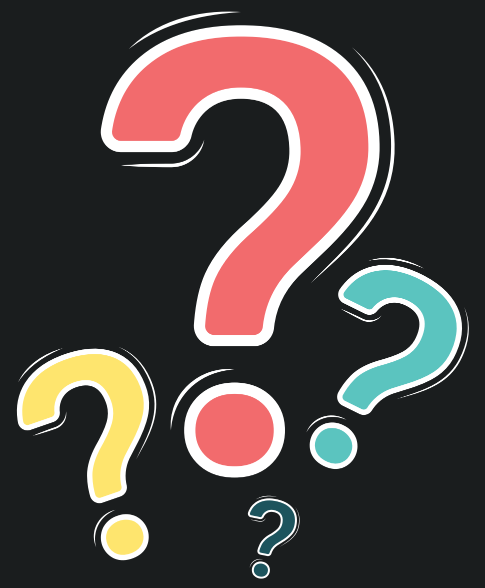
2. Executive Summary

3. Introduction
    - **3.1 Findings Summary**
    - 3.2 Findings Details
    - 3.3 Remediation

Ref. ID	Title	Risk Level
1	User Authentication Bypass	High

4. Appendices

Questions?



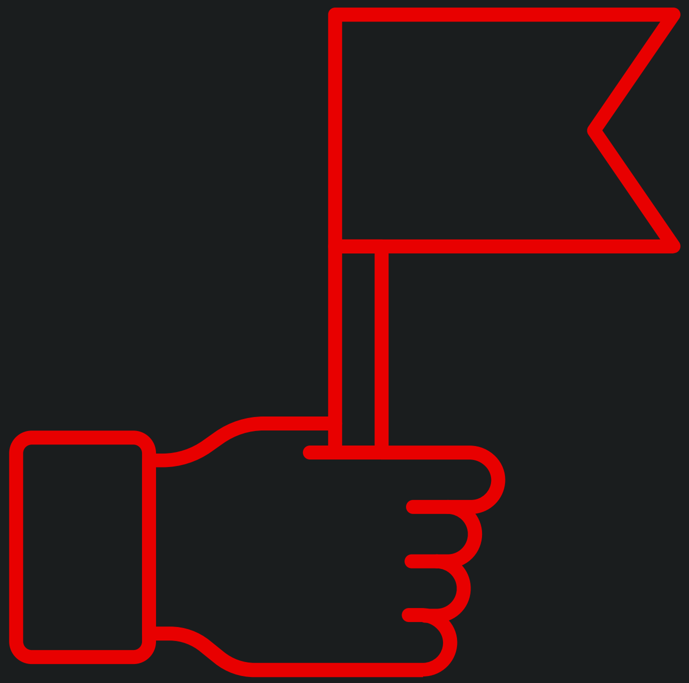
Resources

- OWASP
- The HackTricks Book
- PayloadsAllTheThings
- Portswigger Academy ♥
- HackTheBox Academy

For the rest of the evening ...

Solve the other challenges at:

https://ddcpentest.haaukins.com/



DE DANSKE
CYBERMESTERSKABER

WE WANT YOUR
FEEDBACK

PENETRATION TESTING
EVALUATION QR CODE

1. marts 2025

Contact

Shreyas Srinivasa

shreyas.srinivasa@proton.me

Web: https://sastry17.github.io

Thats all Folks